

AWS WAF (Web Application Firewall)

What is WAF?

WAF (Web Application Firewall) is a security layer that monitors, filters, and blocks HTTP/S traffic to and from a web application. It helps protect applications from common web exploits that could affect availability, compromise security, or consume excessive resources.

Why We Need WAF on a Load Balancer?

Integrating WAF with a Load Balancer allows centralized and scalable protection against malicious traffic before it reaches the backend servers. This ensures better performance, reduced attack surface, and centralized management of rules.

Importance of WAF

- Protects against common web attacks like SQL injection, Cross-site scripting (XSS), etc.
- Adds an additional layer of security for web-facing applications.
- Ensures compliance with security standards like PCI DSS.
- Reduces potential downtime due to attacks.

Types of AWS WAF Rules

1. AWS Managed Rules: Pre-configured rule sets created and maintained by AWS to protect against common threats.
2. Custom Rules (My Managed Rules): Rules created and customized by the user to meet specific application needs.
3. Rule Groups: A collection of rules grouped together for easy management.
4. Rate-based Rules: Limit the number of requests from a specific IP address over a time window.

AWS Managed Rules vs My Managed Rules

AWS Managed Rules:

- Automatically updated by AWS.
- Protects against known threats.
- Suitable for general-purpose applications.

My Managed Rules (Custom Rules):

- Defined by the user.
- Tailored to specific application logic.
- Ideal for business-specific requirements or custom threats.

Advantages of Attaching WAF

- Enhanced Security: Blocks malicious requests before reaching your infrastructure.
- Protection Against OWASP Top 10: Safeguards against most common vulnerabilities.
- Customization: Allows setting custom logic for application-specific threats.
- Logging and Monitoring: Provides logs and metrics to monitor and respond to threats.

Example: Protecting a login page from brute-force attacks using rate-based rules.

Disadvantages of Not Attaching WAF

- Increased Risk: Exposure to known and unknown web exploits.
- No Centralized Control: Manual effort to maintain security at the application level.
- Higher Recovery Costs: Increased risk of downtime, data theft, and incident recovery.

Example: A public-facing API without WAF becomes vulnerable to SQL injection, compromising sensitive data.